

## 小南总结

这道题主要考 供应链攻击（サプライチェーン攻撃）下的企业整体安全治理，重点不是单个技术，而是考察零信任、权限管理、日志控、漏洞管理、SBOM 等安全措施的理解和应用。

一句话总结：

考察企业面对供应链攻击时，如何从“边界防御”转向“零信任+多层防御”，并通过认证、权限控制、日志分析、漏洞管理、SBOM等措施降低集团整体风险。

具体考点：

a：边界防御（境界防御）→ 零信任（ゼロトラスト）

传统认为“内部网络可信、外部不可信”，进入内部后容易被攻击。

题目指出 VPN 进入内部后无需认证，说明需要零信任思想。

b：最小权限原则（need-to-know）

员工只给予业务所需最低权限，防止内部横向攻击和信息泄露。

c：默认密码

网络设备出厂时统一设置的密码容易被猜测，需要禁止。

d：SIEM

收集服务器、网络设备、系统日志，通过分析发现攻击迹象。

e：SBOM

软件组成清单（软件名称、版本、开发者等）。

用于应对软件供应链攻击，发现使用的软件组件漏洞。

供应链攻击分类

ビジネスサプライチェーン攻撃：攻击子公司/合作伙伴作为跳板。

サービスサプライチェーン攻撃：攻击云服务、IT服务供应商。

ソフトウェアサプライチェーン攻撃：攻击软件开发、开源组件。

漏洞管理

不能只在系上漏洞，需要定期漏洞断（3个月～1年）。

集安全治理

子公司不能各自管理，需要统一安全标准、事件响应流程、开发委托审查等。

整题核心：

“内部≠安全，供应链≠可信，需要零信任思想，对所有访问进行认证、授权、监控，并掌握软件资产信息。”

次の問1は必須問題です。必ず解答してください。

問1 企業グループのセキュリティ対策に関する次の記述を読んで、設問に答えよ。

Z社は、産業機械を製造する企業で、L社をはじめとする複数の子会社を含めてZ社グループを形成している。Z社グループでは、Webベースの業務システムが複数運用されており、グループ各社が共通で利用できる共通業務システムと各社内だけから利用できる個別業務システムの2種類がある。共通業務システムはZ社の内部ネットワーク内のセグメントG中に構築され、グループ各社の拠点間を接続したインターネットVPN経由でアクセスされる。個別業務システムは各社が個別に構築しており、インターネットVPN経由も含めて社外からはアクセスできない。

業務システムは全てZ社グループ外に委託して開発したものであり、共通業務システムの運用管理はZ社の情報システム部が、個別業務システムの運用管理は各社の情報システム部が、それぞれ行っている。業務システムが稼働しているサーバ及び従業員が使用しているPCについては、各社の情報システム部が設定及び運用管理をしている。Z社グループのネットワーク構成（抜粋）を図1に示す。

Z社は总部，L社等子公司。各公司通过VPN使用总部的共用系统，同时也有自己的内部系统。系统由外包开发，**共用系统**由总部管理，各公司的电脑、服务器和**内部系统**由各自管理。

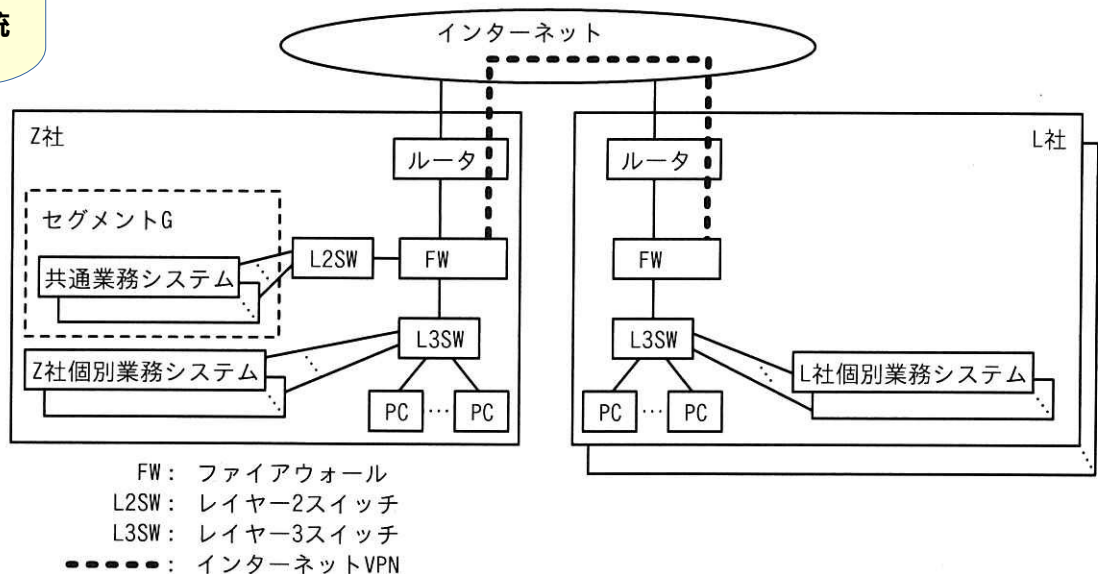


図1 Z社グループのネットワーク構成（抜粋）

〔Z社の現状のセキュリティ対策〕

Z社は、信頼できる領域と信頼できない領域を定め、必要な管理策を実施している。

利用部署在网络边界的防火墙（FW）过滤来自互联网的访问，只允许符合条件的通信进入内部网络，所以采用的是“境界防御”的思想。

对策2： 安装恶意软件防护软件，防止恶意软件感染。

对策3： 定期确认漏洞信息，及时打补丁和更新。

对策4： 上线前进行漏洞诊断，修复后再投入使用。

Z 社の現状のセキュリティ対策は次のとおりである。

対策 1： a の考え方にに基づき、インターネットから Z 社の内部ネットワークへの攻撃を入口となる FW で防いでいる。具体的には、子会社からのインターネット VPN 経由での共通業務システムへのアクセスは許可し、インターネットから Z 社内へのその他のアクセスは、共通業務システムへのアクセスも含めて禁止している。

対策 2： Z 社内の、PC 及び業務システムが稼働しているサーバにはマルウェア対策ソフトを導入している。

対策 3： Z 社内の、PC、業務システムが稼働しているサーバ及びネットワーク機器に対し、各ベンダーからの脆弱性情報やアップデート情報を日次で確認して、適宜セキュリティパッチの適用やアップデートを実施している。

対策 4： Z 社内の業務システムは、導入時に脆弱性診断を実施している。脆弱性が発見された場合は、利用開始までに対応を実施している。

なお、各子会社については、それぞれ独自にセキュリティ対策を実施している。

#### 〔サプライチェーン攻撃の調査〕

ある日、Z 社の情報システム部の B 部長は、同業他社においてサプライチェーン攻撃による被害の事例が複数報告されていることを知り、T 主任にサプライチェーン攻撃の事例を調査して整理するように指示した。

T 主任が調査した結果、サプライチェーン攻撃には幾つかのパターンがあることが分かった。T 主任が整理したパターンを次に示す。

##### (1) ビジネスサプライチェーン攻撃

標的とする会社の、セキュリティ対策が不十分な子会社や取引先などの関連会社を攻撃して、そのシステムを踏み台として、内部ネットワークなどを経由して標的とする会社を攻撃する。

##### (2) サービスサプライチェーン攻撃

標的とする会社が利用している IT サービスの運営事業者などを攻撃して、そのサービスのアカウントを乗っ取ったり、そのサービスを経由してマルウェアを配布したりすることによって、最終的に標的とする会社を攻撃する。

#### 供应链攻击!

业务 → 攻击合作伙伴（子公司、供应商）  
服务 → 攻击云服务/IT 服务商  
软件 → 攻击软件开发商或开源组件

### (3) ソフトウェアサプライチェーン攻撃

標的とする会社の業務システムなどに導入しているソフトウェアの開発会社を攻撃してソースコードを改ざんしたり、業務システムなどで利用しているオープンソースのソフトウェアライブラリの脆弱性を利用したりすることによって、最終的に標的とする会社を攻撃する。

(1)～(3)のパターンについて、T 主任が B 部長に報告したときの会話を次に示す。

B 部長： サプライチェーン攻撃に対して、Z 社グループの現状のセキュリティ対策は十分ですか。

T 主任： 不十分だと思います。Z 社については、a の考え方で内部ネットワーク内の機器の防御を行っているので、攻撃者によって内部ネットワークに侵入されてしまうと、内部ネットワーク内の業務システムなどが容易に攻撃されるおそれがあります。

B 部長： なるほど。実際、幾つかの共通業務システムは、インターネット VPN 経由も含む内部ネットワークからであれば認証無しでアクセスすることが可能なので、内部ネットワークに侵入された場合に情報漏えいのリスクがあるということですね。その他の懸念はありますか。

T 主任： 業務システムについても懸念があります。システム導入以降は脆弱性診断を実施しておらず、導入以降に明らかになった脆弱性への対応ができていないおそれがあります。また、Z 社グループ全体に視野を広げると、マルウェア対策ソフトの選定やネットワーク機器の設定など、各社がそれぞれ独自にセキュリティ対策を実施しているので、セキュリティ対策が不十分な会社が存在するおそれがあります。

B 部長： 分かりました。今後は各社任せにするのではなく、我々 Z 社が中心となって Z 社グループ全体のセキュリティ対策を強化していく必要がありますね。Z 社グループ全体として追加すべきセキュリティ対策を検討してください。

#### 〔追加すべきセキュリティ対策〕

T 主任は Z 社グループ各社の現状のセキュリティ対策を調査し、追加すべきセキュリティ対策を検討して次のようにまとめた。なお、子会社に対してはこれらの対策

以前主要防外部攻击，现在还要防“内部人”，即使攻击者进入内网，也不能随意访问系统，因此要加强内部访问控制、定期查漏洞，并统一管理整个集团的安全。



B (Need to Know) : 员工只能访问完成工作所需要知道 (Need to Know) 的信息和系统, 不授予超出业务需要的访问权限, 从而降低信息泄露风险。

C (デフォルトパスワード) : 题干提到“同一型号设备通常共用的密码”, 因此可判断为默认密码, 应修改为难以猜测的密码。

D (SIEM) : 题干提到“分析日志以发现攻击征兆和尽早发现攻击”, 因此可判断为SIEM, 用于集中收集、关联分析日志, 监测安全事件。

に加えて, ① Z 社グループ全体の統制を強化しサプライチェーン攻撃のリスク又は被害を低減する施策の実施を依頼する。

対策 5 : 全ての業務システムへのアクセスに対しては, 従業員ごとに割り当てた ID とパスワードによる認証を行う。また, パスワードは類推されにくいものだけが利用できるようにシステムで制限する。加えて, b の原則に従い, 各従業員に対して過剰な権限を与えないようにする。

対策 6 : 機密性の高い内部情報を扱う業務システムへのアクセスに対しては, 多要素認証を行う。

対策 7 : ネットワーク機器などの管理用アカウントのパスワードは類推されにくいものにする。特に, 機器の型番ごとに共通であることが多い c パスワードの利用は禁止する。

対策 8 : 業務システム, 業務システムが稼働しているサーバ及びネットワーク機器へのアクセスについては監視及びログの記録を行い, それらのログを d で分析することによって攻撃の予兆検知や早期発見を図る。また, 業務システムやインターネットへのアクセスログが記録されていることを Z 社グループ各社の従業員に周知し, ②データの持出しなどの内部不正を抑止する。

対策 9 : 業務システム, 業務システムが稼働しているサーバ及びネットワーク機器については, 機密情報の取扱いの有無などの重要度に応じて 3 か月から 1 年の周期で定期的な脆弱性診断を行い, 発見された脆弱性への対応を行う。

T 主任が検討の結果を B 部長に報告したところ, ③ソフトウェアサプライチェーン攻撃への対策として“対策 9”に加えて実施すべき内容があると指摘された。そこで T 主任は, 業務システムなどで使用しているソフトウェア製品及びライブラリについて, 名称, バージョン, 開発会社名などを一覧にまとめた e を作成することを, “対策 10”としてセキュリティ対策に追加することにした。

T 主任は“対策 10”も含めて B 部長に改めて報告し, 追加すべきセキュリティ対策が承認された。

①Z社グループ全体の統制を強化し  
サプライチェーン攻撃のリスク又  
は被害を低減する施策

ア ☒ 开发前审查委托开发公司的  
安全措施。属于供应链管理，正  
确。

イ ☒ 集团统一制定安全事件报告  
和应对流程。加强集团统制，正  
确。

エ ☒ 集团统一网络设备配置策  
略。统一安全策略，正确。

ウ ☒ (答案) 把各公司的业务系  
统放到同一个网络段 (セグメント  
G)，但仍由各公司各自管理。

这没有实现题干要求的“由 Z 社统  
一加强管理”，反而只是改变了网  
络位置，管理方式没有改变，也不  
能有效降低供应链攻击风险。

業務システムやインターネットへの  
アクセスログが記録されていること  
を Z 社グループ各社の従業員に周知し、  
②データの持出しなどの内部不正を抑  
止する。  
就直接回答 不正を行うと、**発覚リスト**  
があると分かっているから  
ばれるなど、也可以

設問 1 本文中の  ,  ,  ,  に入れる適切  
な字句を、それぞれ解答群の中から選び、記号で答えよ。

解答群

- |           |          |                |        |
|-----------|----------|----------------|--------|
| ア CASB    | イ MDM    | ウ need-to-know | エ RASP |
| オ SBOM    | カ SIEM   | キ SLCP         | ク 境界防御 |
| ケ サンドボックス | コ ゼロトラスト | サ 多層防御         |        |

設問 2 本文中の  に入れる適切な字句を、5 字以内で答えよ。

設問 3 [追加すべきセキュリティ対策] について答えよ。

(1) 本文中の下線①について、具体的な施策として適切でないものを解答群の  
中から選び、記号で答えよ。

解答群

- ア Z 社グループ各社で業務システムを開発する場合、開発委託先の会社にお  
いてセキュリティ対策が十分に実施されているかを委託前に審査する。
- イ Z 社グループ各社でセキュリティインシデントが発生した場合の報告及  
び対応のフローを定める。
- ウ Z 社グループ各社の個別業務システムを全てセグメント G に移動し、シ  
ステムの詳細を把握している各社の情報システム部が引き続き管理する。
- エ Z 社グループ各社のネットワーク機器の設定ポリシーを強固なものに統  
一する。

(2) 本文中の下線②について、内部不正の抑止につながる理由を 30 字以内で答  
えよ。

(3) 本文中の下線③について、B 部長は何を懸念して指摘したと考えられるか。  
脆弱性対策の観点に着目して 35 字以内で答えよ。

T 主任が検討の結果を B 部長に報告したところ、③ソフトウェアサプライチェーン 攻撃への対策と  
して“対策 9”に加えて実施すべき内容があると指摘された。そこで T 主任は、業務システムなど  
で使用しているソフトウェア製品及びライブラリについて、名称、バージョン、開発会社名などを  
一覧にまとめた e を作成することを、“対策 10”としてセキュリティ対策に追加することにした。

这里就是考为什么要做一个 SBOM，就直接  
背一下脆弱性が発見された際に、**影響範囲を迅速に判断**できないこと